IT SERVICE MANAGEMENT AND OPERATIONAL INCIDENT PROCESS

SOP-015 | Standard Operating Procedure | Issued under POL-015

Document ID: SOP-015
Version: 1.0 — DRAFT
Parent Policy: POL-015 — IT Service Management and Operational Incident Policy
Classification: Internal Use
Owner: CIO
Co-Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	IT Service Management and Operational Incident Process
Document ID	SOP-015
Version	1.0 — DRAFT
Parent Policy	POL-015 — IT Service Management and Operational Incident Policy
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-007 (Change Management), POL-010 (IS Risk), POL-011 (Business Continuity), POL-012 (Incident Response), SOP-006 (Validation Process), SOP-007 (Change Management Process), SOP-010 (IS Risk Process), SOP-011 (BC/DR Process), SOP-012 (Security Incident Response Process), EXC-001 (Exception Management)
Owner	CIO
Co-Owner	Information Security Manager
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

NOTE: This SOP governs operational IT incidents — unplanned service disruptions caused by hardware failure, software faults, infrastructure problems, or configuration error where there is no confirmed or suspected malicious intent. Any operational incident where malicious intent is identified or suspected must be immediately escalated to SOP-012 (Security Incident Response). Both processes may run in parallel if an operational incident reveals a security element.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the end-to-end process for managing operational IT incidents — from initial detection through to resolution, closure, and problem management. It operationalises POL-015 by specifying the severity classification criteria, Incident Management Team (MIT) activation thresholds, GxP and SOX-specific response requirements, the Major Incident Process, escalation to BC/DR, and the Problem Management lifecycle.

The process serves three purposes simultaneously: restoring service as quickly as possible (operational), protecting the validated state of GxP systems (regulatory), and generating the evidence base for SOX ITGC controls (compliance). These priorities occasionally require additional steps that slow service restoration — for example, the requirement to assess validated state before a GxP system restarts. This SOP sets out explicitly where these additional steps apply and why they are non-negotiable.

2. Incident Classification

Priority	Business Impact Criteria	System Tier	Response Target	MIT Activation
P1 — Critical	Complete unavailability of a service used by >50% of the business. GxP activities stopped across one or more production systems. Financial close activities halted. Patient safety or regulatory compliance immediately at risk.	Tier 1 outage, or outage of a Tier 2 system that is a critical dependency of a Tier 1 system.	Acknowledgement: 15 minutes. Initial response: 30 minutes. Resolution: 4 hours.	CIO: 15 minutes. Compliance / QA Director: 30 minutes (GxP systems). Finance Controller: 30 minutes (SOX systems). All MIT members within 1 hour.
P2 — High	Significant service degradation affecting >20% of users. GxP system degraded but not completely unavailable. Single department halted.	Tier 1 degradation, or Tier 2 outage.	Acknowledgement: 30 minutes. Initial response: 2 hours. Resolution: 8 hours.	Senior IT support lead. CIO briefed within 1 hour. Compliance / QA for GxP systems.
P3 — Medium	Service degradation with workaround available. Single user group affected. No GxP or financial system impact.	Tier 2 degradation, or Tier 3 outage.	Acknowledgement: 2 hours. Initial response: 4 hours. Resolution: 24 hours.	IT support team. Service Desk Lead.

Priority	Business Impact Criteria	System Tier	Response Target	MIT Activation
P4 — Low	Minor inconvenience. No business process impact. Individual user or workstation.	Tier 3/4, or individual device.	Acknowledgement: 4 hours. Resolution: 72 hours (within next maintenance window).	Service Desk.

NOTE: For GxP systems: classify based on the higher of business impact and GxP regulatory impact. A GxP system with only 5 users that is required for batch release is a P1 if batch release is halted — regardless of the number of affected users.

3. Incident Lifecycle

Step 01	**Detection and Logging** Incidents are detected through: — Automated monitoring alerts (infrastructure, application, network) — SIEM alerts (POL-014) — note: SIEM alerts with security indicators must be evaluated for SOP-012 escalation — User reports via Service Desk — Vendor notifications — Proactive monitoring by IT operations team On detection, the Service Desk (or IT team member receiving the alert) creates an Incident Record in the ITSM platform immediately: — Incident ID assigned automatically — Affected system(s) and their tier and regulatory flags — Initial description: what is the symptom, when did it start, what is the user impact — Initial severity classification — Detection source For P1/P2: notification immediately to CIO and relevant MIT members per Section 2. No investigation before notification — notification and investigation run in parallel.	Responsible **Service Desk / IT Operations**
Step 02	**Classify and Escalate** Service Desk or IT Operations confirms or revises the initial severity classification within the acknowledgement window. Escalation rules: — If GxP system is confirmed affected: Compliance / QA Director notified immediately, regardless of severity level. There is no minimum severity threshold for GxP notification — Compliance / QA is notified for every GxP system incident. — If SOX system is confirmed affected at P1/P2: Finance Controller notified. — If a security element is suspected: SOP-012 initiated immediately, in parallel. Do not wait for confirmation. — If severity should be higher than initially logged: reclassify and activate the higher-severity response immediately. Severity is always assessed at the system level, not the ticket level. Multiple P3 tickets affecting the same system that together indicate a P1 impact are escalated to P1.	Responsible **Service Desk Lead / CIO**

Step 03	**Investigate and Diagnose** The assigned IT team (tier-appropriate) diagnoses the root cause while simultaneously working to restore service. Investigation activities: — Review system logs, infrastructure monitoring, and SIEM alerts — Identify recent changes: check ITSM change calendar for changes implemented in the prior 48 hours (a common cause of P1 incidents is a change with delayed side effects — this is also an SOP-007 failure mode worth raising as a problem) — Identify the failure component: application, infrastructure, database, network, external dependency, configuration — Assess lateral impact: what other systems or users are affected? Is this spreading? All investigation activities, findings, and timestamps are recorded in the Incident Record as the investigation progresses. The Incident Record is the contemporaneous record of the incident — it is a quality record for GxP systems and an ITGC evidence record for SOX systems.	Responsible **IT Technical Team**
Step 04	**Resolve** Resolution restores service within the classification's resolution target. All resolution actions that involve changes to production systems are implemented as Emergency Changes under SOP-007 — even during an active incident. The change record links to the incident record. 'Emergency' status applies when the incident P1 or P2 status justifies bypassing the standard change window and CAB approval. GxP system resolution requirements: — Every resolution action affecting a GxP system is discussed with Compliance / QA Director in real time before implementation where time permits — For configuration changes that may affect validated state: Compliance / QA Director provides real-time guidance on the validation implications — All resolution steps are recorded with timestamps — the audit trail of the incident response is itself a GxP quality record SOX system resolution requirements: — Finance Controller notified of all resolution actions affecting financial data — Financial data integrity confirmed before system is returned to production use	Responsible **IT Technical Team / Data Custodian (IT) / Compliance QA (GxP)**
Step 05	**Confirm and Close** The incident is not closed until service is confirmed restored — not just 'system is back up'. Confirmation requirements: — IT operations confirms: system is running, monitoring is active, no recurrence in 30-minute observation window — System Owner confirms: business process is functional — For GxP systems: validated state assessment completed per Section 5 of this SOP. GxP Restart Authorisation issued by Compliance / QA Director. GxP activities confirmed not resumed until this step is complete. — For SOX systems: Finance Controller confirms financial data integrity. ITGC evidence confirmed preserved. Incident Record updated: — Root cause (preliminary — confirmed by Problem Management) — Resolution actions taken — Confirmation timestamps — Total duration Incident closed in ITSM. Users notified of resolution.	Responsible **IT Technical Team / System Owner / Compliance QA / Finance Controller**
Step 06	**Post-Incident Review and Problem Management** For P1 and P2 incidents: a Post-Incident Review is conducted within 5	Responsible **CIO / Service Desk Lead**

	business days of closure. PIR confirms: — Root cause: confirmed (not preliminary) — Timeline: detection-to-resolution, with SLA achievement confirmed or gap documented — Response effectiveness: were escalations timely? Was MIT composition appropriate? Were communications effective? — Recurrence risk: is this likely to happen again? Problem Record raised if any of the following apply: — P1 incident (mandatory) — Three or more P2/P3 incidents with the same root cause within 90 days — Root cause not fully understood — GxP system incident with any validated state impact Problem Record initiated in ITSM. Problem Management process begins (Section 6).	

4. Major Incident Process

The Major Incident Process is activated for all P1 incidents. It establishes a dedicated command structure and communication cadence for the duration of the incident.

MIT Role	Member	Responsibilities
Major Incident Commander	CIO (or senior IT manager designated by CIO during out-of-hours)	Commands the incident response. Makes escalation decisions. Owns the stakeholder communications. Single point of accountability.
Technical Lead	Data Custodian (IT) or senior IT engineer	Leads technical diagnosis and resolution. Provides technical status to MIT Commander at 30-minute intervals.
GxP Lead	Compliance / QA Director	Assesses GxP impact in real time. Confirms validated state implications. Authorises GxP activities to continue or stop. Issues GxP Restart Authorisation at resolution.
Finance Lead	Finance Controller	Confirms SOX system financial data integrity status. Authorises financial system restart. Coordinates with external auditors if ITGC evidence is affected.
Communications Lead	Service Desk Lead	Issues status updates to stakeholders per communication cadence. Manages escalation list. Updates executive stakeholders.
CISO Liaison	Information Security Manager	Monitors for security indicators during incident. Triggers SOP-012 immediately if security element identified. Provides security clearance perspective at resolution.

4.1 Communication Cadence

Audience	Frequency During P1	Content
MIT members (internal working group)	Every 30 minutes	Current status, diagnosis progress, estimated resolution, blockers, next 30-minute plan
CIO, CISO, CEO (if >2 hours unresolved)	Every hour	Business impact summary, estimated resolution time, actions taken, escalation needs
Affected users	On detection, then every 60 minutes, then on resolution	Plain language: what is affected, estimated restoration time (if known), workaround instructions
Compliance / QA (GxP systems)	Continuous — they are MIT members	Real-time involvement; they receive all MIT working group updates
Board / external stakeholders (if regulatory notification required)	As required by SOP-012 / regulatory obligation	Per applicable regulatory notification requirements

4.2 BC/DR Escalation

The MIT Commander escalates to BC/DR (SOP-011) when any of the following conditions are met:

- RTO is breached: resolution is not achievable within the system's RTO and the DR plan is the fastest available recovery path
- MTPD is at risk: the incident timeline and current progress indicate that MTPD may be breached before resolution
- Multi-system impact: the incident has spread to multiple Tier 1 systems and cannot be resolved through normal incident response
- Infrastructure loss: primary datacenter or cloud region is unavailable and DR activation is required for recovery

BC/DR escalation is a joint decision: CIO and CISO. CIO assumes IT Recovery Command per SOP-011. The SOP-015 Major Incident Process continues to run alongside SOP-011 for communication management and GxP/SOX coordination, until SOP-011 supersedes it at BC/DR closure.

5. GxP-Specific Incident Requirements

The following requirements apply to every incident affecting a GxP-flagged system, regardless of severity. There is no minimum severity threshold — every GxP system incident invokes these requirements because the potential impact on validated state and data integrity is always present.

Step 01	**Immediate Compliance / QA Notification** Compliance / QA Director is notified of every GxP system incident at the time of initial classification — not after initial diagnosis. The notification includes: system affected, initial description of the incident, time of detection, current service status. Compliance / QA Director determines in real time whether GxP activities must be halted. GxP activities may continue during an incident only if Compliance / QA Director has confirmed that the incident does not affect the systems or data flows used for those activities.	Responsible **Service Desk / IT Operations**
Step 02	**Audit Trail Continuity Assessment** During every GxP incident, the DIO confirms audit trail status: — Is the audit trail still recording? — Is the SIEM receiving log forwards from the GxP system? — Are timestamps in the audit trail correct? If audit trail recording stops or a gap is detected: immediate escalation to SOP-012 and SOP-003 simultaneously. This is treated as an audit trail integrity incident until proven otherwise.	Responsible **DIO / IT Operations**
Step 03	**Resolution Action Validation Impact Assessment** Before any resolution action is implemented on a GxP system: Compliance / QA Director assesses in real time whether the proposed resolution action could affect the validated state. The assessment is brief but explicit: — Does this action change any configuration parameter in the validated baseline? — Does this action affect any data flow that handles GxP records? — Does this action affect the audit trail configuration? If any answer is yes: the action is an Emergency Change with validation impact, requiring retrospective qualification per SOP-006 Section 6.1 within 10 business days. If all answers are no: Compliance / QA Director confirms in the Incident Record ('No validated state impact — [action] approved'). This confirmation is a GxP quality record.	Responsible **Compliance / QA Director**
Step 04	**Data Integrity Verification** Before GxP activities resume, Compliance / QA Director and DIO confirm: — Data in the GxP system is complete, accurate, and consistent with the state before the incident — If data restoration from backup was required: RPO confirmed; restored data integrity verified; no GxP records lost beyond the acceptable window — Audit trail records for the incident period are present and intact; if records are absent (system was down), the absence is documented and the fact that no GxP activities occurred during the outage is confirmed	Responsible **DIO / Compliance / QA**
Step	**GxP Restart Authorisation**	Responsible

05	Compliance / QA Director issues a GxP Restart Authorisation confirming: — Technical recovery confirmed by Data Custodian (IT) — Audit trail integrity confirmed (or gap documented with investigation plan) — Data integrity verified — Validated state: maintained / retrospective qualification required but GxP activities may resume for [scope] / full re-qualification required (GxP activities halted pending completion) GxP Restart Authorisation is signed by Compliance / QA Director and CIO. It is filed in the VMF (Section 13 — Operational Incident Records) and in the ITSM incident record. It is retained as a GxP quality record per POL-002. GxP activities may not resume before this authorisation is issued.	**Compliance / QA Director / CIO**
Step 06	**VMF Documentation** Within 10 business days of GxP system incident closure: — VMF Section 13 updated with: incident ID, description, timeline, resolution actions, audit trail assessment, data integrity confirmation, validated state assessment, GxP Restart Authorisation — If the incident had validated state impact: CAPA raised and tracked in VMF Section 11 — Regulatory notification assessment documented: did this incident require notification to FDA, EMA, or MHRA? Compliance / QA Director confirms decision and rationale. VMF documentation for GxP incidents is a quality record and is subject to inspection by regulatory authorities.	Responsible **Compliance / QA / Validation Lead**

6. Problem Management

Problem Management addresses the root cause of recurring or high-impact incidents. Where the Incident Management process prioritises speed of service restoration, Problem Management prioritises permanent prevention of recurrence. The two processes operate on different timelines and with different success criteria.

Step 01	**Problem Record Creation** A Problem Record is raised in the ITSM platform: — Automatically: for all P1 incidents at closure — Manually: by Service Desk Lead or CIO where three or more P2/P3 incidents with apparent common cause occur within 90 days, or where an incident had validated state impact on a GxP system Problem Record contains: linked incident IDs, symptom description, known impact, initial root cause hypothesis, assigned Problem Manager, target root cause analysis completion date.	Responsible **Service Desk Lead / CIO**
Step 02	**Root Cause Analysis (RCA)** The Problem Manager (typically the senior IT engineer for the affected system, supported by Data Custodian IT) conducts the RCA: RCA methodology — either or both: — 5 Whys: iteratively ask 'why' until the fundamental cause is identified (not the proximate cause) — Fishbone /	Responsible **Problem Manager / Compliance QA (GxP)**

	Ishikawa diagram: categorise contributory causes across: People, Process, Technology, Environment RCA looks for root cause at the system level, not the incident level. The root cause is usually a weakness in a control, a design gap, a process that was not followed, or an undetected dependency. A root cause that is 'human error' is almost always incomplete — the question is why the human error was possible and was not caught. For GxP incidents: RCA is a CAPA process and must be conducted with Compliance / QA involvement. The CAPA standard for GxP root cause is higher than for non-GxP systems — 'we patched it' is not a CAPA.	
Step 03	**Known Error Register** Where a root cause has been identified but the permanent fix is not yet implemented, a Known Error Record is created: — Known error ID — Description of the error and its trigger conditions — Workaround: how to resolve incidents caused by this known error quickly if it recurs before the fix is in place — Permanent fix: the planned corrective action and its target implementation date — Risk assessment: what is the impact if the error recurs before the fix is implemented? The Known Error Register is reviewed weekly by the Service Desk Lead and monthly by the CIO. Known errors with a High or Critical risk assessment are flagged to the IS Risk Register (SOP-010).	Responsible **Problem Manager / Service Desk Lead**
Step 04	**Change Request Initiation** The permanent fix identified in the RCA is implemented through the SOP-007 Change Management Process: — Normal change request raised in ITSM, linked to the Problem Record — The Change Request references the root cause and the Known Error entry — For GxP systems: Validation Impact Assessment included in the change request per SOP-007 Section 7 — CAB reviews and approves the change per SOP-007 — On implementation: Problem Manager confirms the fix resolves the root cause — this requires evidence, not assumption	Responsible **Problem Manager / Information Security Manager**
Step 05	**Problem Closure** The Problem Record is closed when: — The permanent fix has been implemented and confirmed effective — For non-GxP systems: 30-day monitoring period with no recurrence of the related incident type — For GxP systems: 30-day monitoring period with no recurrence, CAPA completed and confirmed effective, VMF updated, Compliance / QA Director confirms closure Problem Records are never closed on the basis that the fix has been implemented — closure requires confirmed effectiveness. A fix that addresses the symptom but not the root cause will result in recurrence within the monitoring window. Closed Problem Records are retained in the ITSM system for 7 years per POL-002. For GxP incidents, the Problem Record and its CAPA are also retained in the VMF.	Responsible **Problem Manager / CIO / Compliance QA (GxP)**

7. Decision Table — Cross-Policy Triggers

The following table defines the mandatory cross-policy actions triggered by specific conditions during an operational incident. These are not recommendations — they are mandatory actions with named owners.

Trigger Condition	Mandatory Action	Owner	Reference
Malicious activity confirmed or suspected during incident investigation	Immediately initiate SOP-012. Both SOP-015 and SOP-012 run in parallel. CISO notified immediately.	MIT Commander / Information Security Manager	SOP-012 Section 7
RTO breached or MTPD at risk	Jointly escalate to SOP-011 BC/DR. CIO commands recovery workstream. SOP-015 continues in parallel for communications.	CIO + CISO	SOP-011 Section 8
Any GxP system incident	Compliance / QA Director notified immediately. GxP Restart Authorisation required before GxP activities resume. VMF documentation within 10 business days.	Service Desk / Compliance QA Director	This SOP Section 5
Audit trail gap or anomaly detected on GxP or Tier 1 system	Immediate escalation to SOP-012 and SOP-003 simultaneously. DIO notified within 15 minutes.	IT Operations / DIO	SOP-012 Section 6.4; SOP-003
Resolution requires a production change	Emergency Change initiated under SOP-007. Change record linked to incident record. Compliance / QA involvement for GxP changes.	Data Custodian (IT) / Information Security Manager	SOP-007 Section 6
Privacy / personal data breach suspected	DPO notified immediately. GDPR 72-hour clock running. SOP-004 DPIA reassessment triggered.	MIT Commander / DPO	SOP-012 Section 5; SOP-004
SOX ITGC evidence affected	Finance Controller and Internal Audit notified at P1/P2. Financial data integrity confirmed before restart. External auditors informed if material.	Finance Controller	POL-015 Section SOX; POL-002
IS risk identified during incident	IS Risk Register updated via SOP-010. New risk entry created. CISO notified if Critical or High.	Information Security Manager	SOP-010 Section 6

8. Related Documents

Document ID	Title	Relationship
POL-015	IT Service Management and Operational Incident Policy	Parent policy — this SOP operationalises POL-015
POL-005	System Classification Policy	System tier determines P1/P2 classification, MIT activation thresholds, and GxP flag triggers mandatory Compliance / QA involvement for every incident
POL-006	Computer System Validation Policy	GxP system incidents require validated state assessment per this SOP Section 5; incidents affecting validated configuration require retrospective qualification per SOP-006
POL-007	Change Management Policy	All resolution actions involving production changes are Emergency Changes under SOP-007; Problem Management permanent fixes are Normal changes
POL-010	Information Security Risk Policy	Incidents revealing systemic IS risk fed to IS Risk Register via SOP-010; Known Errors with High/Critical risk assessment added to IS Risk Register
POL-011	Business Continuity Policy	P1 incidents breaching RTO escalate to SOP-011 BC/DR invocation; dual command structure (CIO IT recovery; CISO security investigation)
POL-012	Incident Response Policy	Security elements identified during operational incidents trigger immediate SOP-012 initiation; both processes run in parallel
SOP-003	Data Integrity Process	GxP audit trail gaps during incidents trigger SOP-003 DIRA deviation process simultaneously with SOP-012
SOP-006	Computer System Validation Process	GxP Restart Authorisation process follows SOP-006/SOP-011 validated state restoration procedure; VMF documentation mandatory for GxP incidents
SOP-007	Change Management Process	Emergency Change procedure covers all incident resolution changes; Problem Management permanent fixes are Normal changes through SOP-007
SOP-010	IS Risk Assessment Process	Incidents with IS risk implications trigger IS Risk Register updates via SOP-010
SOP-011	BC/DR Process	RTO breach escalation; SOP-011 invocation decision; GxP validated state restoration follows

Document ID	Title	Relationship
		SOP-011 Section 6
SOP-012	Security Incident Response Process	Boundary conditions defined in this SOP Section 7 and SOP-012 Section 7; security element in operational incident triggers SOP-012 immediately
EXC-001	Exception Management Policy and Register	Operational incidents used as grounds to bypass change management or validated state requirements are not EXC-001 exceptions — they are Emergency Changes. There is no exception process for bypassing GxP Restart Authorisation.
RACI-001	Roles, Responsibilities and Authorities	Accountability for IT service management governance

— End of Document —

SOP-015 v1.0 DRAFT | [Company Name] | INTERNAL USE